

Vulnerability Assessment Report

DownUnderNewsz — External Network & Web Application Penetration Test Report

DownUnderNewsz

22 Arthur St
Fairfield VIC 3078, Australia

September 18, 2026

Report Version: 1.0

Flinders University
Sturt Road, Bedford Park SA
5042

Table of Contents

List of Figures	3
1 Document Control	4
1.1 Team	4
1.2 List of Changes	4
2 Executive Summary	5
2.1 Overview	5
2.2 Identified Vulnerabilities	6
3 Methodology	8
3.1 Objective	8
3.2 Scope	8
3.3 User Accounts and Permissions	9
4 Findings	10
M1: Backend Application Server Directly Reachable, Bypassing HTTPS/ Reverse Proxy	10
M2: Anonymous FTP Access Exposes Files on Media Server	11
M3: Missing Security-Related HTTP Response Headers	12
I1: Administrative Login Panel Publicly Exposed Without Additional Protection	13
I2: Domain Missing DMARC Record (Email Spoofing Exposure)	14
I3: TLS Certificate Does Not Cover the "www" Hostname	15
5 Disclaimer	16
A Appendix	17
A.1 Static Appendix Section	17

List of Figures

Figure 1 - Distribution of identified vulnerabilities	7
---	---

1 Document Control

1.1 Team

Contact	Details	Role
ClawSec	Autonomous agent	Pentester

1.2 List of Changes

Version	Description	Date
1.0	Initial report version	Sep 18, 2026

2 Executive Summary

2.1 Overview

Overview

DownUnderNewsz engaged an external security assessment of its public-facing internet presence: the main news website (thedownundernews.online and its www version) and a separate media/asset server used to host images and files. Both are run on dedicated servers hosted by OVH in Australia. The assessment was conducted over a single day on 18 September 2026, with explicit authorization confirmed directly with the business beforehand.

What we found

The good news first: **no critical or high-severity issues were confirmed**. The website and its infrastructure are, overall, a small and manageable footprint, and nothing found during this assessment indicates that customer data or the website's core content has already been compromised.

Two issues deserve prompt attention:

1. **An unprotected file-sharing service on the media server.** The server that hosts images and other media files has a file-transfer service (FTP) configured to allow anyone on the internet to connect and download files without a username or password. At the time of testing this only exposed a handful of non-sensitive files, but the lack of any access control means anything placed there in the future—intentionally or by mistake—would be publicly accessible to anyone who knows where to look.
2. **A backend "side door" that skips the website's normal encryption.** The main website is properly protected with HTTPS (the padlock icon visitors expect), but the underlying application server can also be reached directly over an unencrypted connection on a separate port. This means the encryption protecting the site—including the administrator login page—can be bypassed entirely if someone knows this alternate path exists, exposing login attempts and other traffic in plain, readable text.

The remaining four findings are lower-priority "hardening" items: the website is missing some standard browser security protections, the security certificate does not cover the "www" version of the site (causing a browser warning for some visitors), the domain has no protection in place against attackers sending fake emails that appear to come from @thedownundernews.online, and the administrator login page is reachable by anyone on the internet without any extra layer of restriction.

Business impact, in plain terms

None of these issues show evidence of a past or ongoing breach. However, left unaddressed, the two medium-severity items in particular increase the chance that a determined attacker could intercept administrator credentials or access files that should not be public. All identified issues have practical,

low-cost fixes that a web hosting administrator or developer can implement, most within a few hours of work.

Recommended priorities

1. Turn off anonymous access on the media server's file-transfer service.
2. Block public internet access to the backend application port so all traffic is forced through the encrypted website.
3. Add standard browser security headers, fix the certificate for the "www" address, publish an email anti-spoofing (DMARC) record, and restrict access to the admin login page.

Full technical detail, evidence, and step-by-step remediation guidance for each item is provided in the findings section of this report.

2.2 Identified Vulnerabilities

#	CVSS	Description	Page
M1	5.9	Backend Application Server Directly Reachable, Bypassing HTTPS/Reverse Proxy	10
M2	5.3	Anonymous FTP Access Exposes Files on Media Server	11
M3	4.3	Missing Security-Related HTTP Response Headers	12
I1	0.0	Administrative Login Panel Publicly Exposed Without Additional Protection	13
I2	0.0	Domain Missing DMARC Record (Email Spoofing Exposure)	14
I3	0.0	TLS Certificate Does Not Cover the "www" Hostname	15

Vulnerability Overview

In the course of this penetration test **3 Medium** and **3 Info** vulnerabilities were identified:

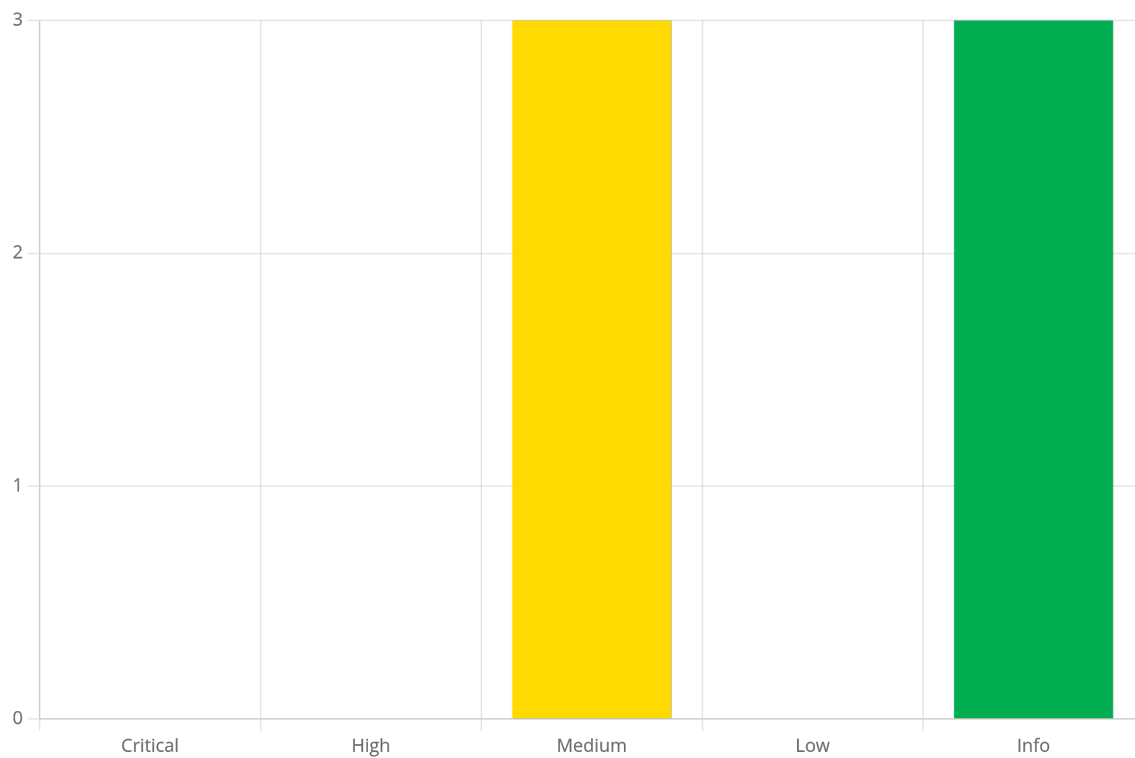


Figure 1 - Distribution of identified vulnerabilities

3 Methodology

This entire vulnerability assessment process was completed using agentic AI and existing LLM models. The purpose of such assessments is to automatically

3.1 Objective

The entire objective of this research is to evaluate the effectiveness of autonomously evaluate security posture for any business available on Google Map without the needs of technical guidance to determine how feasible, seamless and cost-affective such approach is.

3.2 Scope

This was an external network and web application security assessment covering DownUnderNewsz's confirmed internet-facing assets:

Asset	Type	Notes
thedownundernews.online	Root domain / main website	Primary news website
www.thedownundernews.online	Subdomain	www alias of main website
media.thedownundernews.online	Subdomain	Media/asset server
51.161.130.70	Server (OVH, Australia)	Hosts the main website/application
51.161.131.195	Server (OVH, Australia)	Hosts the media server

Out of scope / excluded from testing: third-party DNS and mail-relay infrastructure operated by the domain registrar (spaceship.net nameservers and efwd.spaceship.net mail relay), third-party content delivery networks (Google Fonts, jsDelivr), an unresolvable legacy domain alias (thedownundernews.it.com) referenced only in the site footer, and the broader OVH network block (AS16276) beyond the two confirmed servers above. These are noted for context only and were not tested.

Methodology

Testing combined passive and light-touch reconnaissance (DNS records, certificate transparency logs, WHOIS, and Shodan) to confirm the asset inventory, followed by network service enumeration (nmap), review of TLS/SSL certificate configuration, review of HTTP security headers, web content discovery, and targeted, non-destructive testing of discovered functionality (search, contact form, administrative login page, and anonymous FTP access) for common vulnerability classes including cross-site scripting, SQL injection, CORS misconfiguration, information disclosure, and authentication/access-control weaknesses.

Limitations

- Anonymous FTP **read** access on the media server was confirmed; **write/delete** capability could not be safely validated within the engagement's safety controls and remains an open question the business should verify directly.
- media.thedownundernews.online returned a 502 Bad Gateway error during testing, indicating its backend application was down or misconfigured; deeper application-level testing of this subdomain beyond confirming the outage was not possible.
- No credential brute-forcing, password spraying, social engineering, phishing, denial-of-service, or other destructive/prohibited techniques were performed, per the engagement's rules of engagement.
- Subdomain discovery relied on subfinder, assetfinder, crt.sh, and Shodan (the `amass` tool was unavailable in the assessment environment).

3.3 User Accounts and Permissions

No credentials or user accounts were provided by the client. All testing was performed from an unauthenticated, external attacker's perspective.

4 Findings

M1: Backend Application Server Directly Reachable, Bypassing HTTPS/Reverse Proxy	
Score	5.9 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Target	51.161.130.70:5000 (Gunicorn application server, main website's backend)
References	• CWE-319 (Cleartext Transmission of Sensitive Information) • CWE-668 (Exposure of Resource to Wrong Sphere)

Overview

Severity: Medium

The website's backend application server is directly reachable from the internet over plain, unencrypted HTTP on port 5000, completely bypassing the HTTPS encryption and the nginx web server that normally sits in front of it.

Details

Port scanning of 51.161.130.70 revealed an open port 5000 running Gunicorn (the Python application server that powers the website). Direct requests to `http://51.161.130.70:5000/` return the exact same application - including the search page and the administrative login page (`/admin`) - as the properly encrypted `https://thedownundernews.online/`. Because this path is unencrypted, any sensitive data submitted through it (most notably, administrator login credentials, since the `/admin` login form is reachable the same way) would travel in plain text and could be intercepted by anyone positioned on the network path. This exposure also means that the application server itself is directly internet-facing rather than only reachable through the intended nginx front end, removing a layer of defense.

Recommendation

Configure the server's firewall to block external access to port 5000, so the application is only reachable through nginx on ports 80/443 (nginx should proxy to the app server over localhost only, e.g. `127.0.0.1:5000`). This is a standard, low-effort fix that eliminates the unencrypted access path entirely.

M2: Anonymous FTP Access Exposes Files on Media Server	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target	media.thedownundernews.online (51.161.131.195:21, vsftpd 3.0.5)
References	• CWE-287 (Improper Authentication) • CWE-284 (Improper Access Control)

Overview

Severity: Medium

The FTP service on the media server accepts anonymous logins with no username or password required, allowing anyone on the internet to browse and download files stored on it.

Details

A port scan identified an open FTP service (vsftpd 3.0.5) on 51.161.131.195, the server behind media.thedownundernews.online. Testing confirmed the server accepts anonymous login (username "anonymous") and grants read access to a shared directory. At the time of testing this directory contained 4 files (2 images, 1 PDF, 1 HTML file) totalling roughly 1MB, none of which appeared to contain credentials or highly sensitive personal data, but the service itself has no access control at all - any current or future file placed in that directory is exposed to the public internet without authentication. Write/delete capability could not be safely validated during this engagement (a validation attempt was declined by the assessment's own safety controls), so it is unknown whether an anonymous user could also upload or modify content; this should be treated as an open question and verified by the site owner directly.

Recommendation

Disable anonymous FTP login. If the media server needs to serve files publicly, do so over HTTPS from the existing web server instead of via a separate unauthenticated FTP service. If FTP access is required for legitimate internal use, restrict it to authenticated accounts and firewall the port to trusted IP addresses only.

M3: Missing Security-Related HTTP Response Headers

Score	4.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N
Target	thedownundernews.online and www.thedownundernews.online (all pages)
References	• CWE-1021 (Improper Restriction of Rendered UI Layers - Clickjacking) • OWASP Secure Headers Project

Overview

Severity: Low

The website does not send several standard browser security headers, leaving it with fewer built-in protections than modern best practice recommends.

Details

Reviewing the site's HTTP response headers showed none of the following are set: Content-Security-Policy, Strict-Transport-Security (HSTS), X-Frame-Options, X-Content-Type-Options, Referrer-Policy, or Permissions-Policy. In practical terms: the site could be embedded in a hidden frame on a malicious page (clickjacking), browsers won't be told to always use HTTPS for this domain, and there's no defense-in-depth policy restricting what scripts/resources the page can load if an injection flaw is ever found elsewhere.

Recommendation

Add the missing headers at the nginx level (a small, low-risk configuration change): Strict-Transport-Security, X-Frame-Options: DENY (or CSP frame-ancestors), X-Content-Type-Options: nosniff, a baseline Content-Security-Policy, and Referrer-Policy: strict-origin-when-cross-origin.

I1: Administrative Login Panel Publicly Exposed Without Additional Protection

Score	0.0 (Info)
Vector string	N/A
Target	thedownundernews.online/admin (also reachable via 51.161.130.70:5000/admin, see related finding on backend exposure)
References	-

Overview

Severity: Low

The website's admin login page is reachable by anyone on the internet with no additional restriction (such as IP allow-listing or a VPN requirement), increasing the attack surface for credential-guessing attempts.

Details

The page itself only presents a standard username/password login form and does not leak any data to unauthenticated visitors, so this is not a vulnerability on its own. However, combined with the lack of network-level restriction, it broadens the avenues an attacker could use to attempt to guess credentials over time (a technique this assessment did not test, per engagement rules against brute-force attacks). Reducing this exposed surface is a reasonable hardening step.

Recommendation

Restrict access to /admin at the network level (IP allow-list for known administrator locations, or place it behind a VPN), and ensure the underlying account has a strong, unique password and, ideally, multi-factor authentication.

I2: Domain Missing DMARC Record (Email Spoofing Exposure)

Score	0.0 (Info)
Vector string	N/A
Target	thedownundernews.online (DNS zone)
References	-

Overview

Severity: Low

The domain has no DMARC policy published, which makes it easier for attackers to send emails that appear to come from @thedownundernews.online addresses.

Details

A direct DNS query for a DMARC record (_dmarc.thedownundernews.online) returned no result. Without DMARC, even if SPF is configured, receiving mail servers have no instruction on how to handle messages that fail authentication checks, making the domain a more attractive target for phishing campaigns impersonating the business.

Recommendation

Publish a DMARC TXT record starting in monitoring mode (e.g. "v=DMARC1; p=none; rua=mailto:") and gradually move to a stricter policy (p=quarantine, then p=reject) once legitimate mail flows are confirmed to pass authentication.

I3: TLS Certificate Does Not Cover the "www" Hostname

Score	0.0 (Info)
Vector string	N/A
Target	www.thedownundernews.online
References	-

Overview

Severity: Low

Visitors who type "www.thedownundernews.online" into their browser will see a security warning because the site's TLS certificate was only issued for the bare domain, not the www version.

Details

The certificate served on port 443 lists only "thedownundernews.online" in its subject/SAN. When the same server is accessed via the www subdomain, browsers correctly flag a hostname mismatch. The site still loads if the visitor clicks through the warning, but this both damages visitor trust and trains users to ignore certificate warnings.

Recommendation

Reissue the TLS certificate to include "www.thedownundernews.online" as an additional Subject Alternative Name (most certificate providers, including free ones like Let's Encrypt, support multiple SANs at no extra cost), or configure a permanent redirect from www to the bare domain if www is not meant to be used directly.

5 Disclaimer

The purpose of this research project is to help evaluating the seamlessness, effectiveness and cost-benefit ratio of autonomously performing vulnerability assessment using agentic AI. I do not take any responsibility upon any misuse or abuse of such tool where it can face significant legal actions.

A Appendix

A.1 Static Appendix Section